

01

CRITICAL

Security module or WAF disabled

- Enable Proactive Filter and the security module
- Remove broad WAF exclusions; scope to exact paths
- Enable event logging; forward to syslog / SIEM
- Re-check settings after every update and migration

02

HIGH

A WAF does not replace secure code

- A WAF is defense-in-depth, not the final fix
- Fix in code: validation, authorization, parameterization
- Test bypasses: encodings, APIs, HTTP methods, content types
- Ship virtual patches with an expiry date and a fix ticket

03

CRITICAL

Vulnerable code, modules, dependencies

- Update core, modules, PHP, OS and JS dependencies regularly
- Maintain a component inventory / SBOM with owner and support window
- Run SAST and SCA on custom PHP, JS, Composer, npm
- Remove unused modules entirely — do not just hide them

04

CRITICAL

Customizations block CMS updates

- Never modify Bitrix core files directly
- Keep custom code in supported /local/ directories
- Test updates in staging before applying to production
- Document customizations, owners and rollback procedure

05

CRITICAL

Public install and maintenance scripts

- Delete bitrixsetup.php, restore.php immediately after use
- Keep service scripts outside webroot; mount only during the window
- Recursively scan for .bak .old .save .zip suffixes
- Add external checks for known installer paths to CI/CD

06

CRITICAL

Sensitive files and directories in webroot

- Move dumps, backups and .git outside webroot
- Block on the server: .env *.sql *.log .git *.tar.gz
- Disable directory listing and MIME-sniffing
- Probe externally: .git/HEAD .env phpinfo.php dbconn.php

07

HIGH

Debug mode and unsafe logs in production

- debug=false, display_errors=0ff, Xdebug disabled
- Mask secrets, cookies, tokens and PII in logs
- Store logs outside webroot: /var/log/bitrix/
- Rotation, quotas, access limited to the service account

08

CRITICAL

Weak authentication and privilege management

- MFA mandatory for all privileged accounts
- Restrict admin access via VPN or network ACLs
- Individual accounts; principle of least privilege
- Log logins, privilege changes, password resets, MFA disablement

09

CRITICAL

Insecure server / PHP / TLS configuration

- HTTPS + modern TLS + HSTS across all subdomains
- Block PHP execution in /upload, /cache, /tmp
- PHP: hide version, disable_functions, separate process privileges
- Validate uploads: extension, MIME, signature, size

10

HIGH

No AV / EDR or centralized logging

- Deploy independent AV/EDR on the host (not just Bitrix WAF)
- File integrity monitoring for core files, configs, cron jobs and SSH keys
- Forward events to a SIEM — do not keep them local only
- Test backup restoration regularly